

Penetration Testing Report

Mediroza General Hospital — External Web Application Black-Box Assessment

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Engagement Type	Black-box Penetration Test
Batch / Week	B083 / Week 4
Duration	5 Days
Report Classification	CONFIDENTIAL — Authorised Personnel Only
Prepared and Authored by	Adebayo Timothy
Title	Cyber Security Analyst / Consultant

This assessment was conducted under written authorisation from the client, within the agreed scope and rules of engagement. These techniques must never be applied to any system without explicit written permission from the owner.

1. Executive Summary

Networkwalks conducted a black-box penetration test against Mediroza General Hospital's public-facing web application at <https://medirozahospital.com> over a five-day engagement. The objective was to identify exploitable vulnerabilities, demonstrate real-world impact, and provide actionable remediation guidance.

The assessment identified five findings, including two rated Critical. Testing demonstrated that an unauthenticated attacker could fully bypass the Patient Portal's authentication via SQL injection, retrieve confidential patient pathology reports, recover the passwords protecting those reports due to weak and inconsistent password practices, and separately discover a publicly accessible legacy database backup exposing the personal and financial details of all 30 hospital staff members, including national identification numbers, salaries, and the hospital's shareholder register.

Taken together, these findings indicate that an external attacker with no prior access or credentials could compromise both patient confidentiality (a regulated data category) and sensitive corporate/HR data, with minimal technical effort and no social engineering required. Immediate remediation is strongly recommended, prioritised in Section 6.

Summary of Findings by Risk Rating

Ref	Finding	Risk Rating	Milestone
F1	SQL Injection authentication bypass in Patient Portal login	Critical	M1
F2	Unauthenticated directory listing exposing application file structure	Medium	M1
F3	Verbose SQL error disclosure on login form	Low	M1
F4	Weak / inconsistent password protection on patient lab report PDFs	High	M2
F5	Publicly accessible legacy database backup exposing staff PII, salaries and shareholder data	Critical	M3

2. Scope and Rules of Engagement

Target: <https://medirozahospital.com> (and associated infrastructure hosting it)

Test Type: Full black-box penetration test — no credentials or internal knowledge provided

Rules of Engagement: Testing limited to the target domain only. No social engineering. No denial-of-service testing. No testing outside agreed scope.

Authorisation: Written authorisation provided by the client for security testing of their web infrastructure.

3. Methodology — Ethical Hacking Phases

The engagement followed the standard phased methodology recognised in ethical hacking practice. Each phase below maps the recognised objective to the specific activities performed and the outcome achieved against this target.

Phase 1 — Reconnaissance (Passive Information Gathering)

Objective: build an initial picture of the target without directly interacting with it, using only publicly available sources.

- Google dorking against the target domain — filetype, inurl and keyword-based search operators.
- Manual review of indexed pages (homepage, About, Doctors, Contact) for references to internal functionality.

Outcome: no indexed PDFs or admin paths were found, but site navigation text referenced a "Patient Portal", identifying the login page as the first point of interest for the next phase.

Phase 2 — Scanning and Enumeration

Objective: actively map live services, hidden directories and the application's attack surface.

- Nmap service/version scan of the target host to fingerprint exposed network services.
- Gobuster directory and file brute-forcing against the site root and the discovered /patient/ subdirectory.

Outcome: identified open mail/FTP/DNS/HTTP services on shared hosting infrastructure (informational, excluded from further testing per scope); discovered an exposed directory listing at /patient/ (revealing download.php, error_log, login.php, logout.php, portal.php, reports/) and a previously unknown /old/ directory containing a legacy database backup.

Phase 3 — Gaining Access (Exploitation)

Objective: leverage identified weaknesses to obtain unauthorised access.

- Authentication mechanism analysis — tested login error-message behaviour to confirm username enumeration.
- Input validation testing — single-quote probe confirmed SQL injection via a disclosed MySQL syntax error.
- Constructed and submitted an authentication-bypass payload (admin'-- / '--) to the login form.

Outcome: full authentication bypass achieved on the Patient Portal, yielding an authenticated session with access to confidential patient report data.

Phase 4 — Post-Exploitation and Data Analysis

Objective: determine the real-world impact of access gained by analysing what data and further exposure it leads to.

- Retrieved three encrypted patient pathology report PDFs made available through the compromised session.
- Extracted crackable hash representations from each PDF and performed dictionary-based password recovery.
- Reviewed recovered patient data for sensitivity and regulatory relevance.
- Downloaded and analysed the legacy SQL backup discovered in Phase 2, revealing full staff and shareholder records.

Outcome: full compromise of patient confidentiality (3 reports) and of internal HR/shareholder confidentiality (30 staff records, 10 shareholder records).

Phase 5 — Maintaining Access

Not performed. Consistent with the authorised and educational nature of this engagement, no backdoors, persistence mechanisms, or privilege escalation beyond the initial authentication bypass were established. This phase is documented for methodological completeness only.

Phase 6 — Covering Tracks

Not performed. As a fully authorised and transparent engagement, no attempt was made to conceal testing activity, delete logs, or evade detection controls — in line with standard ethical hacking practice of full disclosure to the client.

Phase 7 — Analysis and Reporting

Findings were consolidated, independently risk-rated using CVSS 3.1 principles, and compiled into this report together with prioritised remediation guidance (Sections 5–6).

3.1 Tools Used

Tool	Phase Used	Purpose
Google Dorking	Reconnaissance	Passive discovery of indexed content, file types and paths via search operators
Nmap	Scanning & Enumeration	Network service and version detection against the target host
Gobuster	Scanning & Enumeration	Directory and file brute-forcing to uncover unlinked paths and resources

Tool	Phase Used	Purpose
Browser DevTools	Scanning & Exploitation	View-source / inspect-element analysis of forms, scripts and request structure
curl	Exploitation & Verification	Direct HTTP request testing and resource retrieval
pdf2john	Post-Exploitation	Extraction of crackable hash representations from encrypted PDF files
Dictionary / Wordlist Attack Tool	Post-Exploitation	Recovery of weak PDF passwords via targeted and generic wordlists

3.2 Limitations

A bot-mitigation / anti-automation control was observed in front of at least part of the site: automated requests made via curl to a discovered file path were intercepted and served a JavaScript-based verification challenge rather than the requested content, while the same resource was retrievable through a standard browser session. This indicates partial bot-detection coverage; its exact scope was not fully mapped within the engagement window and is noted for awareness rather than treated as a standalone finding.

Per the rules of engagement, services unrelated to the hospital's own application (FTP, SMTP, POP3/IMAP mail services identified on shared hosting infrastructure during Phase 2) were fingerprinted but not subjected to credential attacks, as they were assessed to belong to the shared hosting provider rather than exclusively to the client.

4. Findings and Proof of Exploitation

F1 — SQL Injection Authentication Bypass — Patient Portal

Risk Rating: **Critical** | **CVSS 3.1 (indicative):** 9.1 (Critical) — AV:N/AC:L/PR:N/UI:N/C:H/I:H/A:N

Description

The Patient Portal login form, located at /patient/login.php, was found to be vulnerable to SQL injection. The application constructs its authentication query by concatenating raw user input directly into a SQL statement without parameterisation or input sanitisation.

Submitting a single quote (') in the username field caused the backend to return a raw MySQL syntax error, confirming that user input reaches the database query unescaped. The login form was also found to disclose different error messages for a non-existent username ("username not found") versus a valid username with an incorrect password ("Incorrect password"), confirming a username enumeration weakness and establishing that the account "admin" exists.

Evidence / Proof of Exploitation

- Input of a single quote (') into the Username field returned: "Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near ''' at line 1".
- Username "admin" with an incorrect password returned the distinct message "Incorrect password", confirming the account exists (enumeration).
- Submitting Username: admin'-- and Password: '-- resulted in a successful authenticated session, redirecting to /patient/portal.php and displaying the "My lab reports" page for the admin account without any valid credentials being supplied.
- The authenticated session granted access to a listing of three confidential patient pathology reports with direct download links.

Impact

An unauthenticated attacker can fully bypass login controls on the Patient Portal and access any account, including administrative functionality, without knowledge of any valid password. In this engagement this directly exposed confidential patient pathology reports; depending on the breadth of portal.php's functionality for the admin account, impact could extend further.

Recommendation

- Rewrite all database queries to use parameterised queries / prepared statements (e.g. PHP PDO or mysqli with bound parameters) — never concatenate user input into SQL strings.
- Apply input validation and output encoding as defence-in-depth, not as the primary control.
- Disable verbose database error messages in production; log errors server-side and return a generic error to the user.
- Normalise authentication error messages so that invalid username and invalid password return an identical, generic response (e.g. "Invalid username or password") to eliminate the enumeration channel.
- Implement account lockout / rate limiting on the login endpoint.

F2 — Unauthenticated Directory Listing Exposure

Risk Rating: **Medium** | **CVSS 3.1 (indicative):** 5.3 (Medium) — AV:N/AC:L/PR:N/UI:N/C:L/I:N/A:N

Description

Directory listing ("Index of /") was found enabled on multiple paths, allowing an unauthenticated visitor to enumerate the full contents of a directory rather than being restricted to linked application pages.

Evidence / Proof of Exploitation

- <https://medirozahospital.com/patient/> returned a full directory listing revealing download.php, error_log, login.php, logout.php, portal.php and a reports/ subdirectory — none of which were linked from the visible site navigation.

- <https://medirozahospital.com/old/> returned a directory listing revealing a single file, `mediroza_db_backup_2019.sql` (see Finding F5).

Impact

Directory listing materially assists an attacker by revealing the application's internal file structure, script names and naming conventions, which in this engagement directly led to the discovery of Finding F5. It also exposed `error_log`, which may contain sensitive runtime/debug information (access to this specific file returned 403 Forbidden during testing and was not reviewed further).

Recommendation

- Disable directory listing / autoindex at the web-server configuration level (Apache: Options -Indexes; equivalent LiteSpeed/HAProxy configuration) across the entire web root.
- Audit all web-accessible directories for files that should not be publicly reachable and remove or relocate them outside the web root.

F3 — Verbose Database Error Disclosure

Risk Rating: **Low** | **CVSS 3.1 (indicative):** 3.1 (Low) — AV:N/AC:L/PR:N/UI:N/C:L/I:N/A:N

Description

The application returns raw PHP/MySQL error output directly to the browser when malformed input is submitted, rather than a generic, user-facing error message.

Evidence / Proof of Exploitation

- See F1 — single-quote input into the login form returned a full `mysqli_query()` warning including SQL syntax detail.

Impact

Verbose error messages assist an attacker in understanding backend technology, query structure and database behaviour, accelerating exploitation. This was a contributing factor in confirming F1.

Recommendation

- Set `PHP display_errors = Off` and configure centralised server-side error logging in the production environment.
- Return generic, non-technical error messages to end users for all application failure states.

F4 — Weak and Inconsistent Password Protection on Patient Report PDFs

Risk Rating: **High** | **CVSS 3.1 (indicative):** 7.5 (High) — AV:N/AC:L/PR:N/UI:N/C:H/I:N/A:N

Description

The three patient pathology report PDFs retrieved via Finding F1 were individually password-protected using standard PDF 128-bit RC4 encryption (Standard Security Handler V2.3). The portal indicates each password is unique and "sent to you by the laboratory". In practice, all three passwords were trivially weak and were recovered within minutes using dictionary-based attacks, with no consistent complexity standard applied across the three files.

Evidence / Proof of Exploitation

- Password hashes were extracted from each PDF using `pdf2john` and cracked via dictionary attack.
- Pathology Report — S. Dlamini (Lab Ref LR-2024-1187): password recovered as "123456".
- Pathology Report — P. Reddy (Lab Ref LR-2024-1192): password recovered as "password".
- Pathology Report — E. Thompson (Lab Ref LR-2024-1205): password recovered as "!@#%&" (a keyboard-pattern string), requiring an expanded wordlist after the two simpler patterns above did not succeed.
- None of the three recovered passwords were derived from patient-specific data (name, date of birth, lab reference number), indicating passwords are manually and inconsistently assigned rather than system-generated.

Impact

Once a report file is obtained (e.g. via F1, or any future access-control failure), the encryption protecting its contents provides negligible real-world protection. Combined with F1, this results in full compromise of confidential patient diagnostic data for the affected patients, including full name, date of birth, patient ID, referring physician and diagnostic results.

Recommendation

- Generate PDF passwords programmatically using a cryptographically random generator (e.g. minimum 12 characters, mixed-case alphanumeric with symbols) rather than manual assignment.
- Migrate to AES-256 PDF encryption (Acrobat 9/ISO 32000-2 compatible) rather than legacy 128-bit RC4.
- Consider whether password-protected file download is the appropriate control at all, given F1 — access control at the application/account layer should be the primary defence, with file encryption as defence-in-depth only.

F5 — Publicly Accessible Legacy Database Backup Exposing Staff PII, Salaries and Shareholder Data

Risk Rating: Critical | CVSS 3.1 (indicative): 9.8 (Critical) — AV:N/AC:L/PR:N/UI:N/C:H/I:N/A:N

Description

A legacy, unauthenticated-accessible directory (/old/) was discovered via directory brute-forcing from the web root. Directory listing was enabled, revealing a single file: mediroza_db_backup_2019.sql — a plaintext SQL database backup of the mediroza_hr database, downloadable by anyone with no authentication.

Evidence / Proof of Exploitation

- Gobuster directory enumeration against the site root (<https://medirozahospital.com>) identified /old/ as a valid, unlisted path.
- <https://medirozahospital.com/old/> returned a directory listing containing mediroza_db_backup_2019.sql (7 KB, dated 2019-08-27 per internal backup header).
- The file itself carries the internal comment: "WARNING: contains confidential staff and shareholder records."
- The staff table contained 30 full employee records (name, role, department, contact details, national ID and exact monthly salary) and the shareholders table contained 10 records detailing the hospital's ownership structure. Both datasets are reproduced in full in Section 4.1 below as evidence of the scale of exposure.

The complete recovered datasets are presented as Table 1 and Table 2 in Section 4.1 (landscape) for full evidentiary clarity.

4.1 Recovered Database Contents (mediroza_hr backup)

Table 1 — Staff Records (30 of 30 recovered)

ID	Full Name	Job Title	Department	Email	National ID	Salary (ZAR/mo)	Date Joined
1	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	r.naidoo@medirozahospital.com	85021013011081	138,000	2009-03-16
2	Sarah Botha	Chief Financial Officer	Finance	s.botha@medirozahospital.com	85031023022082	152,000	2011-07-01
3	Dr. Johan van der Merwe	Medical Director	Management	j.merwe@medirozahospital.com	85041033033083	160,000	2007-01-22
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	a.naicker@medirozahospital.com	85051043044084	132,000	2012-09-10
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	a.kara@medirozahospital.com	85061053055085	128,000	2013-02-18
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	y.cassim@medirozahospital.com	85071063066086	74,000	2018-05-04
7	Michael Roberts	HR Director	Human Resources	m.roberts@medirozahospital.com	85081073077087	96,000	2010-11-15
8	Susan Pretorius	HR Officer	Human Resources	s.pretorius@medirozahospital.com	85091083088088	32,000	2016-08-23
9	Jameel Malik	IT Systems Administrator	IT	j.malik@medirozahospital.com	85101093099080	58,000	2015-04-12
10	Thabo Molefe	Network Engineer	IT	t.molefe@medirozahospital.com	85111103110081	46,000	2017-10-02
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	n.khumalo@medirozahospital.com	85121113121082	34,000	2016-01-19
12	Lerato Mokoena	Registered Nurse	Pediatrics	l.mokoena@medirozahospital.com	85011123132083	33,000	2017-06-07
13	Bongani Ndlovu	Registered Nurse	Cardiology	b.ndlovu@medirozahospital.com	85021133143084	35,000	2015-12-01
14	Zanele Mahlangu	Nursing Sister	Theatre	z.mahlangu@medirozahospital.com	85031143154085	42,000	2013-03-25
15	Kagiso Sithole	Pharmacist	Pharmacy	k.sithole@medirozahospital.com	85041153165086	61,000	2014-09-08
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	n.zulu@medirozahospital.com	85051163176087	26,000	2019-02-14
17	Themba Nkosi	Radiographer	Radiology	t.nkosi@medirozahospital.com	85061173187088	44,000	2016-07-30
18	Palesa Radebe	Radiographer	Radiology	p.radebe@medirozahospital.com	85071183198080	43,000	2017-04-11
19	Deepak Pillay	Lab Technologist	Diagnostics Lab	d.pillay@medirozahospital.com	85081193209081	41,000	2015-05-20
20	Kavitha Govender	Lab Technician	Diagnostics Lab	k.govender@medirozahospital.com	85091203220082	35,000	2018-08-06
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	s.moodley@medirozahospital.com	85101213231083	130,000	2012-02-28
22	Dr. Fatima Patel	Pediatrician	Pediatrics	f.patel@medirozahospital.com	85111223242084	118,000	2013-10-17
23	Nisha Singh	Physiotherapist	Rehabilitation	n.singh@medirozahospital.com	85121233253085	48,000	2016-11-09
24	Dr. Vikram Chetty	Anaesthetist	Theatre	v.chetty@medirozahospital.com	85011243264086	135,000	2011-06-13

ID	Full Name	Job Title	Department	Email	National ID	Salary (ZAR/mo)	Date Joined
25	David Smith	Facilities Manager	Operations	d.smith@medirozahospital.com	85021253275087	52,000	2014-01-27
26	Karen O'Connor	Billing Administrator	Finance	k.oconnor@medirozahospital.com	85031263286088	29,000	2018-03-19
27	James Wilson	Security Supervisor	Operations	j.wilson@medirozahospital.com	85041273297080	27,000	2019-09-02
28	Linda Fourie	Receptionist	Front Office	l.fourie@medirozahospital.com	85051283308081	19,000	2020-02-10
29	Peter van Wyk	Procurement Officer	Supply Chain	p.wyk@medirozahospital.com	85061293319082	38,000	2015-08-24
30	Andile Mbeki	Ward Clerk	Administration	a.mbeki@medirozahospital.com	85071303330083	21,000	2019-11-05

Table 2 — Shareholder Register (10 of 10 recovered)

ID	Shareholder Name	Share %	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18.0%	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
3	Dr. Johan van der Merwe	12.0%	120,000	Ordinary
4	Reddy Family Trust	11.0%	110,000	Ordinary
5	Thabo Molefe	10.0%	100,000	Ordinary
6	Sarah Botha	9.0%	90,000	Ordinary
7	Dr. Ahmed Kara	8.0%	80,000	Preferential
8	Naledi Zulu	7.0%	70,000	Ordinary
9	Michael Roberts	6.0%	60,000	Ordinary
10	Dr. Vikram Chetty	4.0%	40,000	Preferential

Impact

This is the most severe finding of the engagement. It exposes highly sensitive personal information (national identification numbers, a protected identifier under South African POPIA) and compensation data for all 30 hospital employees, as well as confidential corporate ownership/equity information, to any unauthenticated internet user who discovers or guesses the path. This data could facilitate identity theft, targeted social engineering or fraud against named staff, and constitutes a significant regulatory/compliance exposure for the hospital independent of any other finding in this report.

Recommendation

- Remove the /old/ directory (and its contents) from the production web root immediately; backups must never be stored within a web-accessible path.
- Audit the server for any other legacy, backup, or "old"/"bak"/"archive"-style directories and remove or relocate all such content outside the web root.
- Disable directory listing globally (see F2).
- Encrypt all database backups at rest and store them in access-controlled, non-web-facing storage with a defined retention and secure-deletion policy.
- Review whether the national ID and salary data exposure triggers mandatory breach-notification obligations under applicable data protection law.

5. Overall Risk Summary

Of the five findings identified, two (F1 and F5) are rated Critical, representing independent paths to full compromise of either patient confidentiality or staff/corporate confidentiality, each exploitable by an unauthenticated external attacker. Finding F4 (High) compounds F1 by showing that even where an additional protective control (file encryption) exists, weak implementation renders it ineffective. Findings F2 and F3 are lower-severity configuration weaknesses that nonetheless materially assisted discovery of the higher-severity issues and should not be deprioritised, as they are inexpensive to remediate.

Overall, the application's security posture reflects an absence of secure-development practices (parameterised queries, generic error handling) combined with basic infrastructure hygiene gaps (directory listing, forgotten legacy files left in the web root). None of the findings required advanced tooling or significant time investment to discover, indicating the current exposure level is accessible to a low-skilled opportunistic attacker, not only a sophisticated one.

6. Recommendations and Remediation

The following remediation actions are recommended in priority order:

- **Priority 1 — Immediate (24–48 hours):** Remove /old/ and any other backup/legacy content from the web root (F5). Disable directory listing server-wide (F2).
- **Priority 2 — Short-term (1–2 weeks):** Remediate the Patient Portal login SQL injection by migrating to parameterised queries, and normalise authentication error messages (F1, F3).
- **Priority 3 — Short-term:** Rotate/regenerate passwords for all existing protected patient report PDFs using a cryptographically random generator, and review the process by which these passwords are created and communicated (F4).
- **Priority 4 — Medium-term:** Conduct a full audit of the web root for additional unreferenced files/directories, review error-handling/logging configuration across the application, and establish a secure backup-storage process outside the web-accessible path.
- **Priority 5 — Ongoing:** Introduce periodic (e.g. quarterly) external vulnerability scanning and re-test following remediation to confirm findings in this report have been fully resolved.

This concludes the findings of the Mediroza General Hospital penetration testing engagement (Batch B083, Week 4), prepared and authored by Adebayo Timothy, Cyber Security Analyst / Consultant. All testing was performed within the authorised scope and timeframe described in Section 2.